

Identity & Access Governance + Risk Mapping

Master Project Documentation

Build Notes • Validation • Group Policy • Security Auditing • Lifecycle Management

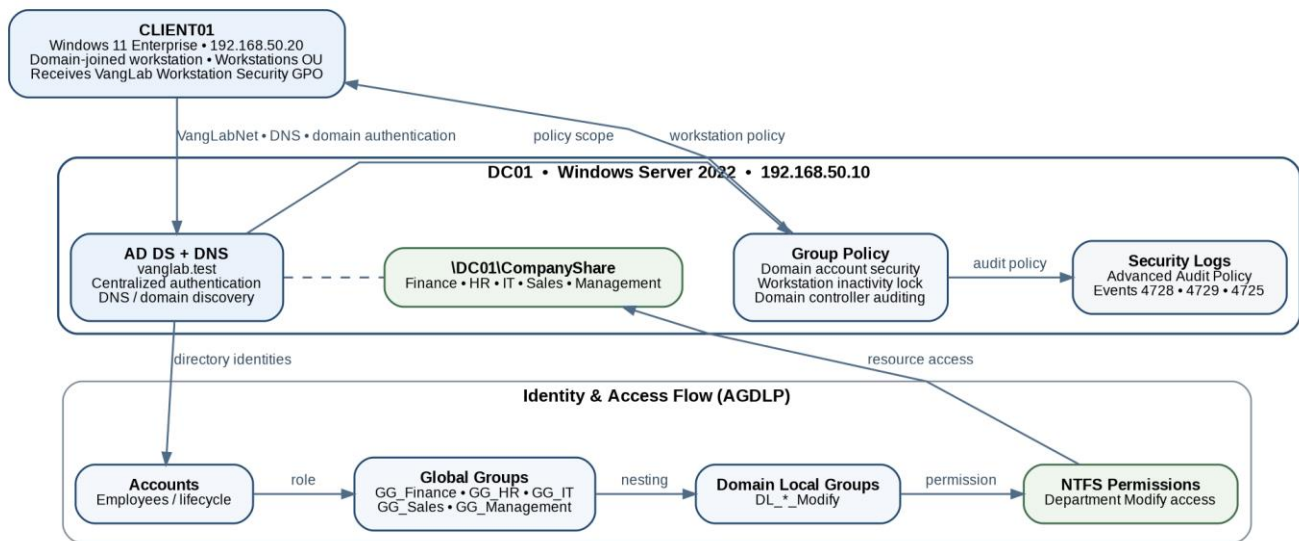
Windows Server 2022 | Windows 11 Enterprise | vanglab.test

Updated August 2026

Project Status Summary

The lab is complete through Phase 10. The original build established Active Directory, AGDLP-based departmental access, a domain-joined Windows 11 client, and access validation. The extension added Group Policy account/workstation security, Windows Security auditing, and a full employee lifecycle scenario.

Phase	Focus	Status
1A	Domain and OU structure	Complete
2	Security groups and membership	Complete
3	CompanyShare and AGDLP permissions	Complete
4	CLIENT01 deployment and domain connectivity	Complete
5	Positive / negative access validation	Complete
6	Risk and framework mapping	Complete / updated
7	Evidence and portfolio preparation	Complete
8	Group Policy and account security	Complete
9	Active Directory auditing	Complete
10	Identity lifecycle management	Complete



Project architecture overview used in the final portfolio package.

Phase 1A - Domain and OU Structure Setup

Date: June 18, 2026

Objective: Establish the Windows Server domain and an organized Active Directory structure that supports centralized identity administration.

Work completed

- Created a Windows Server 2022 virtual machine in Oracle VirtualBox and renamed it DC01.
- Configured a static IPv4 address for the initial server build and installed Active Directory Domain Services (AD DS) and DNS Server.
- Promoted DC01 to a domain controller and created the vanglab.test forest/domain.
- Created the main VangLab OU with Disabled Users, Groups, Service Accounts, Users, and Workstations OUs.
- Created department OUs under Users for Finance, HR, IT, and Sales.

Why this matters

The OU design separates users, groups, workstations, service accounts, and disabled identities so onboarding, offboarding, Group Policy scoping, and access reviews can be managed in an organized way.

Issue and resolution

Some department OUs were initially created at the wrong level of the VangLab OU. They were moved into the correct Users OU after temporarily disabling accidental-deletion protection.

Status: Complete.

Phase 2 - Security Groups and Membership

Date: July 9, 2026

Objective: Build the group-based access structure and assign active employees to common and department-specific security groups.

Work completed

- Reviewed the existing OU and user structure and confirmed department-based Global security groups.
- Added active employees to GG_All_Employees while keeping the disabled/former employee account separate.
- Added each active employee to the appropriate department Global group.
- Created Domain Local security groups for resource permissions using the AGDLP model.
- Confirmed that service accounts and workstation objects were not included in employee groups.

Active employees in GG_All_Employees

- Eva Martinez
- Brian Lee
- Alice Johnson
- Grace Chen
- Daniel Kim
- Carla Nguyen

Excluded: Kyrie Irving - disabled/former employee account.

Why this matters

GG_All_Employees provides a centralized way to grant common access, while department Global groups represent role membership. AGDLP separates user roles from resource permissions and supports consistent least-privilege administration.

Status: Complete.

Phase 3 - Shared Folder and Permission Configuration

Date: July 2026

Objective: Create a centralized company share and apply department-based permissions using AGDLP.

Work completed

- Created \\DC01\\CompanyShare with Finance, HR, IT, Sales, and Management folders.
- Configured DL_CompanyShared_Read with share-level access and nested GG_All_Employees into it.
- Configured GG_Finance -> DL_Finance_Modify, GG_HR -> DL_HR_Modify, GG_IT -> DL_IT_Modify, GG_Sales -> DL_Sales_Modify, and GG_Management -> DL_Management_Modify.
- Assigned each Domain Local Modify group to its matching department folder.
- Configured the CompanyShare root so active employees could reach the share while NTFS permissions protected individual department folders.

Security principles applied

- Role-based access control
- Least privilege
- Group-based permission management
- Separation of user roles from resource permissions
- AGDLP permission model

Status: Complete.

Phase 4 - Domain Client Deployment and Connectivity Validation

Date: July 24, 2026

Objective: Deploy a separate employee workstation for end-to-end authentication and access testing.

Work completed

- Created a Windows 11 Enterprise VM (CLIENT01) with approximately 4 GB RAM, 2 vCPUs, a 64 GB virtual disk, TPM 2.0, EFI, and Secure Boot.
- Configured NAT for internet access and an internal VirtualBox network named VangLabNet for private domain communication.
- Configured DC01 at 192.168.50.10 and CLIENT01 at 192.168.50.20 on the private lab network.
- Configured CLIENT01 to use DC01 (192.168.50.10) as DNS.
- Verified connectivity and Active Directory domain discovery with ping and an LDAP DNS SRV lookup.
- Renamed the workstation to CLIENT01, joined it to vanglab.test, and successfully authenticated Brian Lee.

Issues and resolutions

Employee sign-in to DC01: A regular domain user could not sign in locally to the domain controller. This was recognized as correct security behavior, so CLIENT01 was created for normal employee sign-in and testing.

DNS/domain discovery: CLIENT01 initially used VirtualBox NAT DNS (10.0.2.3), which could not locate vanglab.test. Pointing CLIENT01 to DC01 resolved domain discovery and domain join.

Why this matters

CLIENT01 provides a realistic employee perspective and validates that DNS, authentication, Active Directory groups, and file permissions work together end-to-end.

Status: Complete.

Phase 5 - Access Validation and Review

Objective: Confirm that each employee receives Modify access only to the shared folder required for the assigned department.

User	Department	Expected / validated access	Status
Brian Lee	Finance	Finance Modify; unrelated folders denied	PASS
Alice Johnson	HR	HR Modify; unrelated folders denied	PASS
Daniel Kim	IT	IT Modify; unrelated folders denied	PASS
Carla Nguyen	Sales	Sales Modify; unrelated folders denied	PASS
Eva Martinez	Management	Management Modify; unrelated folders denied	PASS

Controls validated

- Active Directory domain authentication
- Role-based access control
- Group-based permission assignment
- Departmental separation of access
- Least privilege
- AGDLP permission structure
- Share and NTFS permission enforcement

Why this matters

Positive tests proved that required access worked, while negative tests proved users could not reach unrelated department data. This demonstrated that permissions were delivered through role-based groups rather than direct user assignments.

Status: Complete for Finance, HR, IT, Sales, and Management.

Phase 6 - Risk and Security Control Mapping

Objective: Translate the technical build into risk and control language and connect implemented safeguards to current NIST CSF 2.0 and CIS Controls v8.1 outcomes.

Risk	Potential impact	Control implemented	Validation
Excessive / unrelated access	Unauthorized exposure or modification of department data	Department groups and least-privilege NTFS permissions	Positive and negative access tests
Stale access after role change	Users retain access no longer needed	Group membership updated during transfer	Sales access removed; Finance access granted
Former-user access	Former employee can continue authenticating	Account disablement and separation into Disabled Users OU	Fresh sign-in blocked; Event 4725
Direct user permissions	Harder-to-review and inconsistent access	AGDLP and group-based permissions	Access delivered through department groups
Password guessing	Repeated password attempts against domain accounts	Domain password and five-attempt lockout policy	Real lockout and admin recovery tested
Unattended workstation	Authenticated session exposed while user is away	Five-minute inactivity lock	CLIENT01 automatically locked
Untraceable identity changes	No record of who changed memberships/accounts	Advanced Audit Policy on DC01	Events 4728, 4729, and 4725 reviewed

Framework alignment

Implemented activity	NIST CSF 2.0	CIS Controls v8.1
Centralized Active Directory identities	PR.AA-01	5.6 Centralize Account Management
Domain-user authentication	PR.AA-03	6.7 Centralize Access Control
AGDLP / RBAC / least privilege	PR.AA-05	6.7 Centralize Access Control; 6.8 Define and Maintain RBAC
Department NTFS ACLs	PR.AA-05	3.3 Configure Data Access Control Lists
Onboarding / access granting	PR.AA-01; PR.AA-05	6.1 Establish an Access Granting Process
Transfer / access revocation	PR.AA-05	6.2 Establish an Access Revoking Process; 6.8 Define and Maintain RBAC
Termination / account disablement	PR.AA-01; PR.AA-05	6.2 Establish an Access Revoking Process
Workstation security through GPO	PR.PS-01	4.1 Secure Configuration Process; 4.3 Automatic Session Locking
Audit events generated / reviewed	PR.PS-04	8.2 Collect Audit Logs; 8.11 Conduct Audit Log Reviews*

Implemented activity	NIST CSF 2.0	CIS Controls v8.1
Architecture / data-flow documentation	ID.AM-03	12.4 Establish and Maintain Architecture Diagram(s)

**The lab demonstrates audit-log review activity; it does not implement the recurring weekly review cadence described by CIS Safeguard 8.11.*

Status: Complete and updated to NIST CSF 2.0 / CIS Controls v8.1 identifiers.

Phase 7 - Evidence and Portfolio Preparation

Objective: Organize the technical evidence and prepare the project for professional presentation.

- Selected screenshots demonstrating OU structure, security groups, NTFS permissions, authentication, and positive/negative access testing.
- Standardized evidence filenames so each screenshot can be understood without opening it.
- Created the architecture diagram showing DC01, CLIENT01, Group Policy, auditing, AGDLP, and CompanyShare access flow.
- Prepared a concise employer-facing final report separate from the detailed master documentation.

Status: Complete; later phases added additional GPO, auditing, and lifecycle evidence.

Phase 8 - Group Policy and Account Security

Date: August 2026

Objective: Extend the lab from resource authorization into centrally enforced domain-account and workstation security.

Work completed

- Created VangLab Domain Account Security and linked it at the domain level for the lab account-policy configuration.
- Configured a 12-character minimum password length, 12-password history, password complexity, 1-day minimum age, unlimited maximum age, and disabled reversible encryption.
- Configured account lockout after 5 failed attempts, with a 30-minute lockout duration and 30-minute reset window.
- Validated the effective domain policy with gpupdate /force and net accounts /domain.
- Triggered a real lockout from CLIENT01, confirmed the locked state in ADUC, unlocked the user administratively, and verified sign-in afterward.
- Created VangLab Workstation Security and linked it to the Workstations OU.
- Configured Interactive logon: Machine inactivity limit to 300 seconds (5 minutes).
- Verified CLIENT01 received the GPO with gpresult /scope computer /r and confirmed the workstation automatically locked after inactivity.

Troubleshooting note

The built-in Default Domain Policy conflicted with the custom lab account-policy settings during validation. The lab isolated the custom GPO by disabling the Default Domain Policy link and verified the resulting effective policy. This is documented as a lab-specific troubleshooting decision, not a general production recommendation.

Evidence

- Phase8-Effective-Domain-Account-Policy.png
- Phase8-Workstation-GPO-Applied.png

```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Administrator>net accounts /domain
Force user logoff how long after time expires?: Never
Minimum password age (days): 1
Maximum password age (days): Unlimited
Minimum password length: 12
Length of password history maintained: 12
Lockout threshold: 5
Lockout duration (minutes): 30
Lockout observation window (minutes): 30
Computer role: PRIMARY
The command completed successfully.

C:\Users\Administrator>
```

Effective domain account policy.

```
Microsoft (R) Windows (R) Operating System Group Policy Result tool v2.0
© Microsoft Corporation. All rights reserved.

Created on 8/ 15/ 2026 at 3:04:51 PM

RSOP data for on CLIENT01 : Logging Mode
-----

OS Configuration: Member Workstation
OS Version: 10.0.26200
Site Name: Default-First-Site-Name
Roaming Profile:
Local Profile:
Connected over a slow link?: No

COMPUTER SETTINGS
-----
CN=CLIENT01,OU=Workstations,OU=Users,OU=VangLab,DC=vanglab,DC=test
Last time Group Policy was applied: 8/15/2026 at 2:56:58 PM
Group Policy was applied from: DC01.vanglab.test
Group Policy slow link threshold: 500 kbps
Domain Name: VANGLAB
Domain Type: Windows 2008 or later

Applied Group Policy Objects
-----
VangLab Workstation Security
VangLab Domain Account Security

The following GPOs were not applied because they were filtered out
-----
Default Domain Policy
Filtering: Disabled (Link)

Local Group Policy
Filtering: Not Applied (Empty)

The computer is a part of the following security groups
-----
```

Workstation GPO applied to CLIENT01.

Status: Complete.

Phase 9 - Active Directory Auditing

Date: August 2026

Objective: Implement an actual audit trail for important identity and security-group changes on the domain controller.

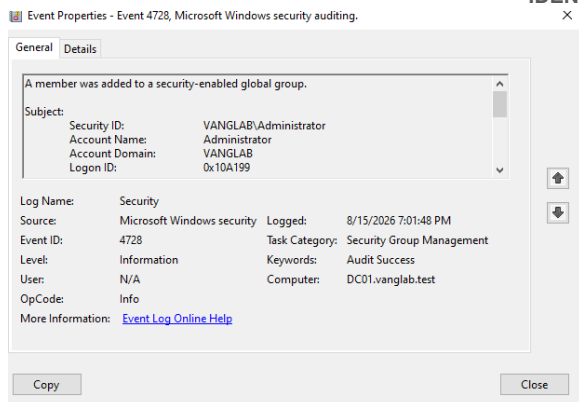
- Created VangLab Domain Controller Auditing and linked it to the Domain Controllers OU.
- Enabled Success auditing for Security Group Management and User Account Management under Advanced Audit Policy Configuration.
- Verified effective auditing with auditpol.
- Created GG_Audit_Test so membership changes could be generated without granting access to a real department resource.
- Confirmed Event 4728 when a member was added to a security-enabled global group.
- Confirmed Event 4729 when a member was removed from a security-enabled global group.
- Confirmed Event 4725 when Marcus Reed was disabled during offboarding.

Why this matters

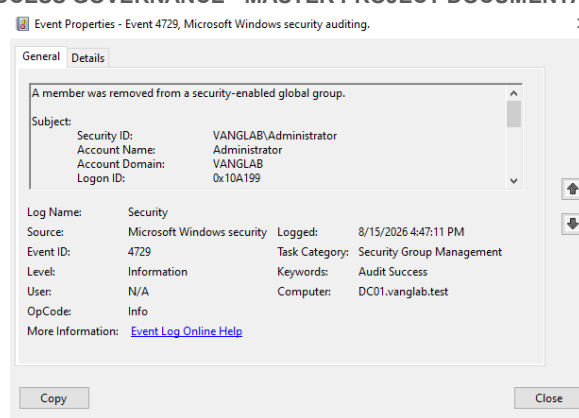
The project can now answer who performed an identity-management change, what was changed, and when it occurred. This is stronger than screenshot-only evidence because the domain controller itself generates attributable Security log records.

Evidence

- Phase9-Domain-Controller-Auditing-GPO-Applied.png
- Phase9-Group-Member-Added-Event-4728.png
- Phase9-Group-Member-Removed-Event-4729.png
- Phase10-Account-Disabled-Event-4725.png



Event 4728 - group member added.



Event 4729 - group member removed.

Status: Complete.

Phase 10 - Identity Lifecycle Management

Date: August 2026

Objective: Demonstrate how access should change as an employee is onboarded, transferred, and offboarded.

Lifecycle scenario

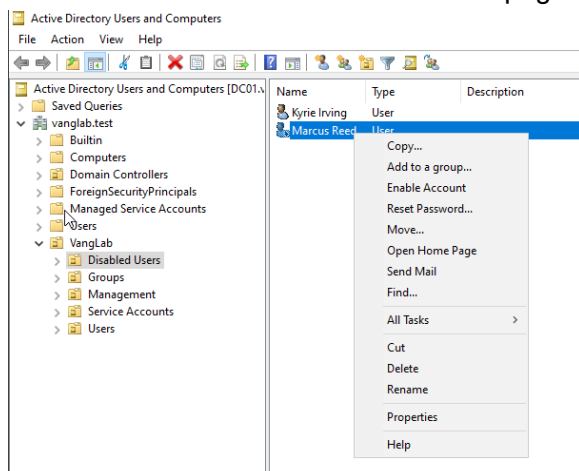
Stage	Administrative action	Validation
Onboarding	Created Marcus Reed in Sales; added GG_All_Employees and GG_Sales	Domain sign-in succeeded; Sales allowed; Finance/HR/IT/Management denied
Department transfer	Removed GG_Sales; added GG_Finance; signed out and back in for a fresh token	Finance allowed; Sales denied
Offboarding	Disabled Marcus Reed and moved him to Disabled Users OU	After full sign-out, fresh domain sign-in was blocked; Event 4725 recorded

Key lesson

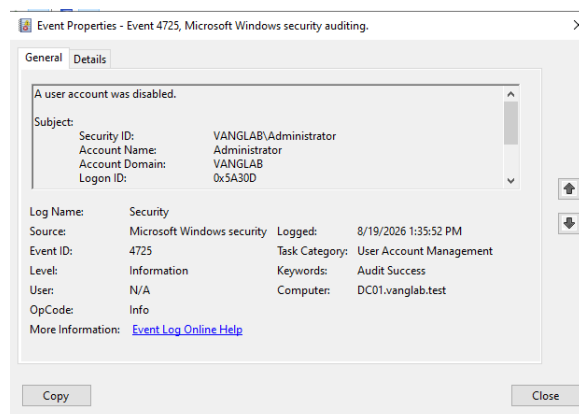
Moving a user between OUs does not automatically change resource permissions. The important access-control action is updating the user's role-based group memberships. A full sign-out is also important because Windows may continue using the security token created at the start of the existing session.

Evidence

- Phase10-Disabled-Former-Employee.png
- Phase10-Account-Disabled-Event-4725.png



Disabled employee separated from active users.



Event 4725 - user account disabled.

Status: Complete.

Final Project Package

The completed portfolio package is designed to separate detailed build history from the concise employer-facing report. The master document preserves the implementation and troubleshooting process, while the final report focuses on outcomes, controls, evidence, and interview-ready project value.

- Identity_Access_Governance_Final_Project_Report_Portfolio_Ready.docx - concise employer-facing final report
- Identity_Access_Governance_Master_Project_Documentation.docx - detailed build and phase record
- VangLab-Architecture-Diagram.png - architecture and access-flow diagram
- Evidence screenshot folder - implementation and validation proof

Final status

Project complete. Optional future stretch labs (such as delegated help-desk administration or PowerShell access-review automation) can be added separately without holding up the core portfolio project.